

Durcissement Avancé Linux - Fichiers, PAM et Traçabilité

- Sécuriser les partitions sensibles via les options de montage (`/etc/fstab`).
- Maîtriser le fonctionnement des modules d'authentification (PAM).
- Mettre en œuvre une protection active contre les attaques par force brute.
- Comprendre le contrôle d'accès obligatoire (MAC) via AppArmor ou SELinux.
- Déployer une traçabilité conforme aux exigences de l'ANSSI via `auditd`.

1. Cloisonnement du Système de Fichiers (`/etc/fstab`)

La séparation des systèmes de fichiers et l'application d'options de montage restrictives constituent une ligne de défense majeure contre l'exécution de codes malveillants, notamment les malwares et les scripts d'élévation de privilèges téléchargés par des attaquants.

1.1 Séparation des partitions sensibles

Le guide de l'ANSSI exige que certains répertoires soient montés sur des partitions dédiées pour éviter la saturation du système (dénis de service) et pour y appliquer des droits spécifiques. Les répertoires clés à séparer de la racine (`/`) sont :

- `/tmp` : Stockage temporaire, cible privilégiée des attaquants pour déposer des charges utiles.
- `/var` : Contient les journaux système (`/var/log`). Si la partition `/` est saturée par des logs, le système s'arrête.
- `/home` : Répertoires utilisateurs.

1.2 Options de montage restrictives

Dans le fichier `/etc/fstab`, des options spécifiques doivent être ajoutées pour restreindre le comportement des systèmes de fichiers :

- `nodev` : Interdit l'interprétation des périphériques de type bloc ou caractère. Indispensable sur toutes les partitions sauf `/`.
- `nosuid` : Ordonne au noyau d'ignorer les bits SUID et SGID présents sur cette partition. Bloque les élévations de privilèges.
- `noexec` : Interdit l'exécution de tout binaire ou script sur la partition.

Exemple de configuration ANSSI pour `/tmp` :

- `tmpfs /tmp tmpfs defaults,rw,nosuid,nodev,noexec,relatime 0 0`

Impact métier : Si un attaquant parvient à exploiter une faille web et télécharge un script malveillant dans `/tmp`, l'option `noexec` empêchera son exécution par le système.

2. Pluggable Authentication Modules (PAM)

Sous Linux, l'authentification n'est pas gérée directement par les applications (comme SSH ou le gestionnaire de session). Elle est déléguée à un framework centralisé appelé **PAM** (situé dans `/etc/pam.d/`).

2.1 Renforcement de la complexité des mots de passe

Le module `pam_pwquality.so` permet de forcer les règles de complexité exigées par les politiques de sécurité (ex: 14 caractères, classes de caractères obligatoires) lors de la commande `passwd`.

2.2 Verrouillage des comptes (Faillock)

Pour contrer les attaques par force brute locale ou réseau, le module `pam_faillock.so` (ou `pam_tally2.so` sur les anciens systèmes) compte les tentatives échouées.

- Il permet de verrouiller temporairement ou définitivement un compte utilisateur après X échecs consécutifs.
- *Note :* Il est recommandé de configurer des alertes sur le déverrouillage du compte `root` pour éviter le blocage de l'administration système.

3. Protection Active contre la Force Brute (Fail2ban)

Alors que PAM gère les règles d'authentification au niveau système, des outils comme **Fail2ban** agissent comme des systèmes de prévention d'intrusion locaux (HIPS).

3.1 Fonctionnement

Fail2ban analyse en continu les fichiers journaux (ex: `/var/log/auth.log` pour SSH, ou les logs Apache/Nginx).

1. Il repère les expressions régulières correspondant à des échecs d'authentification.
2. Si une adresse IP dépasse un seuil d'échecs défini dans un temps imparti (ex: 5 échecs

- en 10 minutes), Fail2ban interagit avec le pare-feu local (`iptables`, `nftables` ou `ufw`).
3. L'IP source est bannie (rejet des paquets) pour une durée déterminée.

3.2 Configuration (Le principe des "Jails")

La configuration s'effectue dans `/etc/fail2ban/jail.local`. Chaque service est protégé par une "prison" (Jail) indépendante.

- `[sshd]`
- `enabled = true`
- `port = ssh`
- `logpath = %(sshd_log)s`
- `maxretry = 3`
- `bantime = 1h`

4. Contrôle d'Accès Obligatoire (MAC)

Le modèle de sécurité standard de Linux (les droits de type `755` ou `chmod`) est appelé **DAC** (Discretionary Access Control). Il est basé sur l'identité de l'utilisateur. Le **MAC** (Mandatory Access Control) ajoute une couche de sécurité basée sur le comportement des processus.

4.1 AppArmor et SELinux

Ces deux systèmes de MAC (AppArmor pour les systèmes basés sur Debian/Ubuntu, SELinux pour Red Hat) restreignent ce qu'un programme a le droit de faire, indépendamment des droits de l'utilisateur qui l'exécute.

- **Scénario** : Si le serveur web Apache est compromis, un attaquant obtient les droits de l'utilisateur `www-data`.
- **Avec le DAC (Standard)** : L'attaquant peut lire le fichier `/etc/passwd` car il est lisible par tous.
- **Avec le MAC (AppArmor)** : Le profil AppArmor dédié à Apache lui interdit formellement de lire un autre répertoire que `/var/www/`, même si les droits standards le permettent. La tentative est bloquée et journalisée.

4.2 Les modes d'exécution

- **Complain (Apprentissage)** : Les violations de règles sont autorisées mais inscrites dans les journaux. Utilisé pour calibrer les règles sans casser la production.
- **Enforce (Blocage)** : Toute violation de la politique de sécurité est strictement bloquée

par le noyau.

5. Traçabilité et Audit (Auditd)

La journalisation standard (Syslog) capture les messages applicatifs. Cependant, l'ANSSI exige une journalisation de bas niveau des appels système, essentielle pour l'investigation numérique (Forensic) post-incident.

5.1 Le démon Auditd

Le composant `auditd` s'interface directement avec le noyau Linux. Il permet d'enregistrer des événements extrêmement précis selon des règles définies dans `/etc/audit/audit.rules`.

5.2 Exemples de cas d'usage de traçabilité

- **Surveillance des fichiers critiques :** Toute tentative de lecture ou de modification du fichier `/etc/shadow` (mots de passe) génère une alerte, en capturant l'UID de l'utilisateur et le nom du programme utilisé.
- **Surveillance des appels système :** Suivi des exécutions de programmes (appel `execve`) pour détecter le lancement d'outils d'administration malveillants.
- **Modification des horloges :** Traçabilité des modifications de l'heure système, souvent utilisées par les attaquants pour fausser la chronologie des journaux.
-